

Narrativa Explicativa del Estudio de Encuesta NIST CSF 2.0

España, resiliencia y métricas en tiempos turbulentos

1. Por qué esta encuesta

La ciberseguridad ha dejado de ser un deporte extremo practicado por minorías en salas oscuras. Hoy es, nos guste o no, parte de la infraestructura básica de un país. La actualización del NIST Cybersecurity Framework a su versión 2.0 refuerza ese mensaje: gestionar la ciberseguridad es gestionar el riesgo, y gestionar el riesgo exige medir.

Esta encuesta nace con una vocación simple y ambiciosa a la vez: tomar el pulso, con números y con honestidad, al modo en que las organizaciones en España están adoptando prácticas alineadas con NIST CSF 2.0, no solo en controles técnicos, sino en gobernanza, métricas, cuadros de mando y retorno de la inversión.

2. El hilo conductor: las seis funciones

El guion principal lo marcan las seis funciones de CSF 2.0: Identify, Protect, Detect, Respond, Recover y, como novedad con brillo propio, Govern. En la práctica, esto significa preguntarnos no solo “qué firewalls tenemos”, sino quién está mirando los indicadores, quién decide cuánto riesgo se acepta, y cómo se traduce todo en prioridades de negocio.

La encuesta recorre estas funciones con preguntas diseñadas para que cada organización pueda reconocerse en un nivel de madurez, más allá de etiquetas de compliance. No se trata de “cumplir o no cumplir”, sino de observar qué procesos están vivos, cuáles son ceremoniales, y dónde reina todavía la improvisación heroica.

3. Tono, ironía y honestidad

Las opciones de respuesta han sido redactadas con un tono deliberadamente humano, a veces irónico, nunca cruel. La intención es doble:

- Ayudar a que quien contesta identifique rápidamente dónde se encuentra.
- Reducir la tentación de responder de forma excesivamente complaciente.

Cuando una opción dice “la política es más literatura que realidad”, no es un reproche personal; es una forma directa de recordar que tener un PDF elegante no iguala a tener un proceso vivo. La encuesta quiere ser espejo, no juicio sumarísimo.

4. Qué medimos y qué no

Medimos:

- La existencia y calidad de estrategias, políticas y apetito de riesgo.
- La capacidad de hacer inventario de activos y datos, y de evaluar riesgos.
- La implantación de controles preventivos, desde identidad hasta parches.
- La cobertura de monitorización y la rapidez con la que se detectan problemas.
- La forma en que se responde a incidentes y se aprende de ellos.
- La resiliencia: qué tal se sobrevive y se recupera cuando las cosas fallan.
- La madurez en gestionar cadena de suministro y terceros, verdadero talón de Aquiles moderno.
- La capacidad de medir todo lo anterior y traducirlo en cuadros de mando y análisis de ROI.

No medimos directamente:

- El número absoluto de ataques que recibe cada organización.
- El detalle técnico de cada herramienta.
- La calidad de configuraciones o reglas específicas.

Esto no es un pentest ni una auditoría de configuración; es una radiografía de madurez de gestión.

5. Qué gana la organización al participar

Más allá del noble placer de contribuir al conocimiento colectivo, cada organización puede obtener:

- Una visión estructurada de su nivel de madurez frente a un marco internacional.
- Un punto de partida para construir (o mejorar) su propio cuadro de mando.
- Argumentos cuantitativos para dialogar con la dirección sobre necesidades de inversión.
- Una comparación —si así se gestiona— con organizaciones similares en sector y tamaño.

Si la encuesta se repite periódicamente, el valor se multiplica: aparecerán curvas de aprendizaje, avances en algunas funciones, estancamientos en otras. Nada ilustra mejor una historia de mejora que un gráfico honesto.

6. De las respuestas a los índices

El Índice Global de Madurez (IGM) no es un veredicto divino; es un resumen numérico de respuestas humanas, con todas sus virtudes y sesgos. Pero es un resumen útil: permite ver, de un vistazo, si la organización se parece más a un programa “Inicial/ad hoc” o a una maquinaria “Gestionada y optimizada”.

Al descomponer el IGM por funciones (GV, ID, PR, DE, RS, RC, SC, métricas), se pueden identificar las asimetrías: organizaciones con buena protección pero pobre gobernanza, con detección aceptable pero recuperación frágil, con mucho control técnico y poca claridad en la cadena de suministro.

7. ¿Y el ROI de todo esto?

Hablar de ROI en ciberseguridad es caminar entre matemáticas, probabilidad y psicología. Aun así, es necesario. Considerar qué habría pasado “sin” ciertas inversiones ayuda a:

- Priorizar proyectos que realmente reducen riesgo.
- Demostrar a la dirección que la ciberseguridad no es solo coste, sino seguro contra pérdidas masivas.
- Alinear mejor los recursos con los riesgos que más duelen cuando se materializan.

La plantilla de Excel propuesta no pretende ser un modelo actuarial perfecto. Es, más bien, una calculadora honesta que invita a poner números —aunque sean estimados— a incidentes, tiempos de parada y exposiciones monetarias. Es mejor un ROI aproximado y discutible que un “no tenemos ni idea”.

8. Cómo leer los resultados sin entrar en pánico

Puede ocurrir que, tras rellenar la encuesta, la organización descubra que su nivel no es tan glorioso como creía. Eso está bien. La alternativa es caminar con la venda puesta.

La clave es usar los resultados para:

- Priorizar las pocas cosas que, si mejoran, cambian el cuadro de forma sustancial.
- Dialogar con la dirección basada en datos, no en relatos apocalípticos.
- Incorporar objetivos concretos a planes y presupuestos.

Nada en el cuestionario pretende humillar a nadie. Si algo duele, probablemente es porque ha tocado una fibra real.

9. Mirada nacional: una foto colectiva

Si este instrumento se usa de forma amplia en España, los resultados agregados permitirán:

- Ver qué funciones CSF están más avanzadas a nivel país.
- Detectar sectores especialmente vulnerables.
- Ajustar políticas públicas, ayudas, formación y regulación.

La ciberseguridad nacional no es la suma aritmética de miles de organizaciones aisladas; es un tejido. Esta encuesta intenta aportar hilos para que ese tejido sea más resistente, menos azaroso, y un poco más consciente de sí mismo.

10. Cierre

En resumen, la encuesta es una invitación: a medir, a reconocerse, a decidir qué se quiere mejorar primero. A dejar atrás la etapa del “tenemos cosas de seguridad” para entrar, con algo de ironía y mucho de rigor, en la era del “sabemos cuánto riesgo asumimos, cuánto reducimos y cómo lo demostramos”.

Responderla puede llevar media hora. Aprovecharla bien puede marcar la diferencia en los próximos años.